

Northgate University

Supplier Security Policy

An ISO/IEC 27001:2013 aligned document · Internal Use Only

Document Reference	NGU-POL-15.1
Version	1.0
Classification	Internal Use Only
Issue Date	01 June 2026
Policy Owner	Chief Information Security Officer
Approved By	Information Governance Board
Next Review Date	01 June 2027
Aligned Standard	ISO/IEC 27001:2013 — Annex A.15

1. Purpose

This policy defines how Northgate University ("the University") manages information security risk arising from its relationships with suppliers and third parties, ensuring that suppliers protect University information to standards consistent with the University's own throughout the supplier lifecycle, in line with ISO/IEC 27001:2013 Annex A.15.

2. Scope

This policy applies to all suppliers, vendors, contractors, and third parties that access, process, store, or transmit University information, or that provide services on which University information systems depend. It applies across the full supplier lifecycle, from selection to termination, and to all staff responsible for engaging or managing suppliers.

3. Supplier Risk Tiering

Suppliers are assessed and managed in proportion to the risk they present, determined primarily by the sensitivity of the information they handle and the criticality of the service they provide. Each supplier is assigned a risk tier:

Tier	Criteria (Data Access / Criticality)	Due Diligence	Review
Tier 1 – Critical	Processes Confidential or personal data at scale, or provides a service critical to University operations.	Full security assessment; certification evidence (ISO 27001 / SOC 2); detailed questionnaire; documented risk assessment; contractual security schedule.	At least annually
Tier 2 – High	Accesses Restricted information, or provides an important (non-critical) service.	Security questionnaire; review of certifications; targeted risk assessment.	Every 1–2 years

Tier	Criteria (Data Access / Criticality)	Due Diligence	Review
Tier 3 – Medium	Limited access to internal information; low operational dependency.	Lightweight questionnaire or self-attestation; standard contractual clauses.	Periodically / on change
Tier 4 – Low	No access to non-public University information.	Baseline contractual terms; no detailed assessment required.	On change only

4. Supplier Security Lifecycle

Information security is managed at every stage of the supplier relationship:

- **Identification and tiering.** The supplier is identified and assigned a risk tier.
- **Due diligence.** The supplier's security is assessed proportionate to its tier.
- **Contracting.** Security and data protection requirements are embedded in the agreement.
- **Onboarding.** Access is provisioned on a least-privilege, time-bound basis.
- **Monitoring and review.** The supplier's security and performance are reviewed on an ongoing basis.
- **Offboarding.** Access is revoked and University information securely returned or destroyed.

5. Due Diligence and Assessment

- Before engagement, suppliers are assessed proportionate to their assigned risk tier (ISO/IEC 27001:2013 A.15.1.1).
- Assessment evidence may include recognised certifications (ISO/IEC 27001, SOC 2), completed security questionnaires, and review of the supplier's security policies and controls.
- Identified risks are documented in the information security risk register and, where significant, treated or escalated before the relationship proceeds.

6. Security in Supplier Agreements

Agreements with suppliers that handle University information include security and data protection requirements proportionate to risk (A.15.1.2). Required terms include:

- Compliance with the University's information security and data protection requirements.
- Confidentiality and permitted use of University information.
- Specific technical and organisational security measures appropriate to the information handled.
- Personal data processing terms compliant with the UK GDPR where the supplier acts as a processor, including controls over sub-processors.
- Mandatory notification of security incidents and personal data breaches within defined timescales.
- The University's right to audit, or to request evidence of, the supplier's security controls.
- Secure return or destruction of University information on termination.

7. ICT Supply Chain

Where suppliers rely on their own sub-suppliers to deliver services to the University, they are required to flow down equivalent information security requirements through the supply chain, and to disclose and control the use of sub-processors that handle University personal data (A.15.1.3).

8. Onboarding and Access

Supplier access to University systems and information is granted on a least-privilege, time-bound basis under the Access Control Policy (NGU-POL-9.1), is uniquely attributable, and is monitored for the duration of the engagement.

9. Monitoring and Review

- Suppliers are reviewed at a frequency proportionate to their risk tier, as set out above (A.15.2.1).
- Reviews consider continued compliance with security requirements, the validity of certifications, and any incidents affecting University information.
- Significant findings are documented and treated as risks, and may trigger re-tiering or remediation requirements.

10. Managing Changes to Supplier Services

Material changes to the services a supplier provides — including changes to the information handled, the sub-processors used, or the supplier's security posture — are reassessed against this policy before they take effect (A.15.2.2).

11. Offboarding and Termination

- On termination or expiry, all University information held by the supplier is securely returned or destroyed, with confirmation obtained.
- All supplier access to University systems and information is revoked promptly.
- Ongoing obligations, such as confidentiality, continue beyond the end of the relationship.

12. Roles and Responsibilities

- **Chief Information Security Officer (CISO).** Owns this policy and the supplier security assessment approach.
- **Procurement and Contract Owners.** Ensure suppliers are tiered, assessed, and contracted in line with this policy, and manage the relationship.
- **Information Asset Owners (IAOs).** Approve supplier access to their information and confirm requirements are met.
- **Data Protection Officer (DPO).** Advises on data processing terms and sub-processor controls.
- **Suppliers.** Comply with the University's security and data protection requirements.

13. Compliance and Enforcement

Compliance with this policy is mandatory. University information must not be shared with, nor systems accessed by, a supplier that has not been assessed and contracted in line with this policy. Supplier non-compliance may result in remediation requirements, suspension of access, or termination of the agreement.

14. Related Policies and Standards

- Information Security Policy (NGU-POL-5.1)
- Access Control Policy (NGU-POL-9.1)
- Information Classification Policy (NGU-POL-8.2)
- Information Security Incident Management Policy (NGU-POL-16.1)
- Information Security Risk Management Policy (NGU-POL-IRM01)
- ISO/IEC 27001:2013 — Annex A.15 (A.15.1, A.15.2)
- UK GDPR and Data Protection Act 2018

15. Document Version History

Version	Date	Author	Summary of Change
1.0	01 June 2026	Chief Information Security Officer	Initial issue. Establishes supplier security and third-party risk requirements.